

# safe-npx technical scope

body

safe-npx is a Rust execution gate for `npx` / `npm exec`. Its first job is to replace the thin yes/no prompt with exact package evidence before remote code runs, then fail closed when inspected bytes cannot be proven to be the bytes that would execute.

## v0.1 must do

- Parse exact-version specs such as `name@1.2.3`
- Reject unsupported specs without raw `npx` fallback
- Download the root tarball without executing scripts
- Verify integrity from registry metadata
- Inspect `package.json`, `bins`, lifecycle scripts, file count, size, and readability signals
- Label dependency declarations as evidence unless the closure is verified
- Print an evidence report and refuse unverifiable execution
- Emit deterministic JSON for agents and CI

## v0.1 should not do

- Replace NPM, PNPM, Yarn, or Bun
- Claim that a package is safe
- Run package lifecycle scripts during inspection
- Depend on a hosted service
- Upload private package metadata by default
- Rely on opaque AI-only scoring
- Attempt perfect JavaScript static analysis
- Claim dependency closure before it is resolved and verified

## Evidence shown before execution

### Artifact

- registry
- package
- version
- tarball URL
- integrity

### Provenance

- publisher
- release age
- maintainers
- repository
- audit status

### Risk signals

- lifecycle scripts
- executable bins
- typo-squat similarity
- bundled or obfuscated code
- dependency declarations

## Rust architecture

### CLI crates

- `clap` for arguments
- `serde` / `serde_json` for reports
- `reqwest` + `tokio` for registry fetch
- `tar`, `flate2`, `sha2`, `base64` for artifacts
- fixture crates for closure and lifecycle-script tests

### Core modules

- package spec parser
- registry client
- tarball verifier
- static signal extractor
- policy evaluator
- execution closure proof
- fail-closed runner

## Primary demo flow

```
$ safe-npx create-example@latest
Package: create-example@2.4.1
Integrity: sha512-...
Published: 3 hours ago
Dependencies: 87 resolved nodes
Lifecycle scripts: postinstall
Recommendation: elevated risk
Continue? [y/N]
```

Public benefit commitments: Apache-2.0 license, reproducible package test corpus, package-manager documentation, agent-vendor JSON schema guidance, and opt-in registry design for exact artifact audit records.